

ชุดโปรแกรมรักษาความปลอดภัยเครือข่าย

นาย เกียรติศักดิ์ เหมกรณ์	46010064
นาย จักรพันธ์ ขวัญเรืองใจ	46010100
นางสาว เอกภักตรา ขวัญเพชร	46010993
อาจารย์ อัครเดช วัชรภูพงษ์	อาจารย์ที่ปรึกษา
ผศ. ธนา หงษ์สุวรรณ	อาจารย์ที่ปรึกษาร่วม
อาจารย์ ธนัญชัย ตริภาค	อาจารย์ที่ปรึกษาร่วม
ปีการศึกษา 2549	

บทคัดย่อ

ในปัจจุบันการรักษาความปลอดภัยระบบเครือข่ายเป็นเรื่องที่สำคัญลำดับแรกสุดที่ต้องคำนึงถึง โดยเฉพาะอย่างยิ่งสำหรับองค์กรที่ต้องการความปลอดภัยสำหรับข้อมูล เครื่องมือแรก ๆ ที่เป็นที่ยอมรับใช้ในการป้องกันการบุกรุกเครือข่ายคงหนีไม่พ้น “ไฟร์วอลล์” ซึ่งถือได้ว่าเป็นอุปกรณ์รักษาความปลอดภัยเครือข่ายที่มีความจำเป็นอันดับต้น ๆ โดยโครงการนี้จะมีการนำไฟร์วอลล์ประเภทมาทำงานร่วมกันเพื่อให้การรักษาความปลอดภัยเครือข่ายเป็นไปได้อย่างมีประสิทธิภาพ ได้แก่ ไฟร์วอลล์ส่วนบุคคล เกตเวย์ไฟร์วอลล์ซึ่งทำงานอยู่บนเกตเวย์ และพร็อกซีไฟร์วอลล์ ซึ่งคือซีเคียวริตี้เว็บพร็อกซี แต่เนื่องด้วยข้อจำกัดของไฟร์วอลล์ที่จะจำแนกแพ็กเก็ตได้ตามกฎที่มีอยู่เท่านั้น ไม่สามารถจำแนกแพ็กเก็ตที่ไม่ตรงตามกฎใด ๆ ได้ อีกทั้งการบุกรุกในปัจจุบันมีความสลับซับซ้อนและมีกลวิธีใหม่ ๆ เกิดขึ้นตลอดเวลา จึงต้องมีการนำระบบจำแนกและบันทึกพฤติกรรมผู้บุกรุกหรือที่เรียกว่า “ฮันนีพอต” เข้ามาช่วยในการป้องกันการโจมตีจากผู้บุกรุกอีกทางหนึ่ง โดยจะช่วยจำแนกแพ็กเก็ตที่ไม่ตรงกับกฎของไฟร์วอลล์ว่าเข้าข่ายบุกรุกหรือไม่ หลังจากนั้นระบบจะทำการคัดแยกผู้ใช้งานที่มีพฤติกรรมที่น่าสงสัยออกจากระบบจริง เข้าสู่ระบบเสมือนเพื่อเฝ้าดูและศึกษาพฤติกรรมต่อไป

NETWORK SECURITY SUITE

Mr. Kiattisak Hamkorn	46010064
Mr. Jakkapan Khwanreungjai	46010100
Ms. Ekpatthra Khwanpetch	46010993
Mr. Akkradach Watcharapupong	Advisor
Asst.Prof. Thana Hongsuwan	Co-Advisor
Mr. Thananchai Treepak	Co-Advisor
Academic Year 2006	

ABSTRACT

At the present time, network security has become the first priority which has to concern, especially for the organizations that their information sensitive. So the organizations have to keep it safe all the time. The most popular security system is “Firewall” as it is one of the must-have security systems. This project combines many types of firewall to work together in order to get the highest efficiency such as a personal firewall with an intrusion detection system, a gateway firewall and a secure reverse web proxy which is a proxy firewall.

However firewall has some exceptions which it works on the knowledge bases the rules that it is set. These make it cannot classify some connections which do not match with the rules. Moreover, nowadays the intruders have many new techniques and tool to intrude the organizations which perhaps firewall cannot protect or prevent. So it's necessary to use Honeypot to solve this problems. Honeypot will detect the packet that does not match with the rules of firewall and classified the intruders from the users. After that it send the intruders to the virtual system, at this we can learn and observe about their techniques which will help us to approve our organization

กิตติกรรมประกาศ

ปริญญานิพนธ์ฉบับนี้สำเร็จลุล่วงไปได้ด้วยดี อันเนื่องมาจากการได้รับโอกาส คำแนะนำ คำสั่งสอน และคำปรึกษาจากท่านอาจารย์อย่างดีเสมอมา โดยเฉพาะอย่างยิ่ง จากท่านอาจารย์อัครเดช วัชรภุมพจน์ ท่านอาจารย์ ธนัญชัย ตริภาก และผู้ช่วยศาสตราจารย์ ธนา หงษ์สุวรรณ ซึ่งต้องขอขอบพระคุณท่านอาจารย์ทั้งสามเป็นอย่างสูง รวมถึงท่านอาจารย์ทุกท่านในภาควิชาวิศวกรรมคอมพิวเตอร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง ที่ได้ประสิทธิ์ประสาทความรู้ใน ทุก ๆ แขนงเป็นอย่างดีเสมอมา

ขอขอบคุณห้องวิจัยและพัฒนาการรักษาความปลอดภัยข้อมูล (ISAG) ภาควิชาวิศวกรรมคอมพิวเตอร์ ที่เป็นแหล่งประสิทธิ์ประสาทความรู้ความเข้าใจ ตลอดจนสนับสนุนเครื่องมือและข้อมูล เพื่อใช้ในการทำวิจัย อีกทั้งเป็นสถานที่ที่เต็มไปด้วยความอบอุ่นจากท่านอาจารย์ เพื่อน ๆ พี่ ๆ ที่คอยให้ คำปรึกษาในการทำวิจัยเป็นอย่างดีเสมอมา

สุดท้ายนี้ข้าพเจ้าขอกราบขอบพระคุณ บิดา มารดา และครอบครัวของข้าพเจ้าที่เป็นกำลังใจ และให้การสนับสนุนในทุกๆเรื่อง ทำให้ข้าพเจ้าสามารถทำปริญญานิพนธ์ฉบับนี้สำเร็จลุล่วงด้วยดี คุณค่าและประโยชน์อันพึงมาจากปริญญานิพนธ์ฉบับนี้ ข้าพเจ้าขอบแต่ผู้มีพระคุณทุกท่าน

นาย เกียรติศักดิ์ เหมกรณ์

นาย จักรพันธ์ ขวัญเรืองใจ

นางสาวเอกภักตรา ขวัญเพชร

สารบัญ

บทคัดย่อภาษาไทย	I
บทคัดย่อภาษาอังกฤษ	II
กิตติกรรมประกาศ	III
สารบัญ	IV
สารบัญตาราง	VIII
สารบัญรูป	IX
บทที่ 1 บทนำ	
1.1 บทนำ	1
1.2 วัตถุประสงค์ของโครงการ	2
1.3 ประโยชน์ที่คาดว่าจะได้รับ	2
1.4 ขอบเขตของโครงการ	2
1.5 ขั้นตอนการดำเนินงาน	3
1.6 เนื้อหาของรายงาน	3
บทที่ 2 ทฤษฎีและหลักการที่ใช้ในการพัฒนา	
2.1 ทฤษฎีและหลักการของไฟร์วอลล์	5
2.1.1 แพ็คเก็ตฟิลเตอร์ริง (Packet Filtering)	5
2.1.2 สเตตฟูลอินสเปกชัน (Stateful Inspection)	6
2.1.3 แอปพลิเคชันพร็อกซี่ (Application Proxy)	7
2.2 ทฤษฎีและหลักการของฮันนีพอต	9
2.2.1 ระบบฮันนีพอตแบบ Low-interaction	10
2.2.2 ระบบฮันนีพอตแบบ High-interaction	10
2.3 ความรู้พื้นฐานเกี่ยวกับการบุกรุก	11
2.4 ระบบตรวจจับผู้บุกรุกผ่านเครือข่าย (NIDS)	13
2.4.1 วิธีการตรวจจับผู้บุกรุกของ NIDS	14
2.5 พร็อกซี่	16
2.5.1 เว็บพร็อกซี่ (Regular Webproxy)	16
2.5.2 รีเวิร์สเว็บพร็อกซี่ (Reverse Webproxy)	16
2.5.3 รีเวิร์สเว็บพร็อกซี่แบบปลอดภัย (Secure Reverse Webproxy)	18
บทที่ 3 การออกแบบและพัฒนา	
3.1 โครงสร้างของโครงการ	19

สารบัญ (ต่อ)

3.2	การออกแบบและพัฒนาซอฟต์แวร์	20
3.2.1	ไฟร์สเตชัน (FireStation)	20
3.2.2	ไฟร์ออลาร์ม (FireAlarm)	20
3.2.3	ไฟร์สกรีน (FireScreen)	20
3.2.4	ไฟร์เบรก (FireBreak)	21
3.2.5	ไฟร์แทรป (FireTrap)	21
3.2.6	ล็อกมอนิเตอร์ (Log Monitor)	21
3.2.7	Tartarus Management	22
บทที่ 4	การพัฒนาระบบไฟร์สเตชัน	
4.1	แนวคิด	23
4.2	ขอบเขตความสามารถ	23
4.3	เทคโนโลยีที่ใช้ในการพัฒนาโปรแกรม	23
4.4	การทำงานของโปรแกรม	26
บทที่ 5	การพัฒนาระบบไฟร์สกรีน	
5.1	แนวคิด	27
5.2	ขอบเขตความสามารถ	27
5.3	เทคโนโลยีที่ใช้ในการพัฒนาโปรแกรม	28
5.3.1	ไอพีเทเบิล (Iptables)	28
5.3.2	สนอร์ตอินไลน์ (Snort_inline)	32
5.3.3	S2I (Snort command to Iptables program)	34
5.3.4	Oinkmaster	34
5.4	การทำงานของโปรแกรม	35
5.4.1	การทำงานร่วมกับไฟร์สเตชัน	35
5.4.2	การทำงานร่วมกับไฟร์แทรป	37
5.4.3	หลักการจำแนกกว่าเป็นผู้บุกรุก	38
5.4.4	หลักการจำแนกกว่าเป็นผู้ใช้ปกติ	39
5.4.5	หลักการจำแนกกว่าเป็นโด้คหนอน	39
บทที่ 6	การพัฒนาระบบไฟร์ออลาร์ม	
6.1	แนวคิด	40
6.2	ขอบเขตความสามารถ	40
6.3	เทคโนโลยีที่เกี่ยวข้องและการพัฒนาโปรแกรม	40

สารบัญ (ต่อ)

6.3.1	Windows Service	41
6.3.2	IPC (Inter Process Communication)	43
6.4	การทำงานของโปรแกรม	47
6.4.1	ไฟร์อลาร์มเซอร์วิส (FireAlarm Service)	48
6.4.2	ไฟร์อลาร์มเซอร์วิสคอนโทรล (FireAlarm Service Control)	51
6.4.2	ไฟร์อลาร์มเอเจนต์ (FireAlarm Agent)	51
บทที่ 7 การพัฒนาระบบไฟร์แทรป		
7.1	แนวคิด	53
7.2	ขอบเขตความสามารถ	53
7.3	เทคโนโลยีที่ใช้ในการพัฒนาโปรแกรม	54
7.3.1	เซเบค (Sebek)	54
7.3.2	แซมเฮน (Samhain)	57
7.3.3	Port Sentry	58
7.4	การทำงานของโปรแกรม	60
บทที่ 8 การพัฒนาระบบไฟร์เบรก		
8.1	แนวคิด	61
8.2	ขอบเขตความสามารถ	61
8.3	เทคโนโลยีที่ใช้ในการพัฒนาโปรแกรม	62
8.3.1	โปรแกรม Squid	62
8.3.2	โปรแกรมสนอร์ตอินไลน์ (Snort_inline)	63
8.4	การทำงานของโปรแกรม	64
บทที่ 9 การพัฒนาระบบล็อกมอนิเตอร์		
9.1	แนวคิด	65
9.2	ขอบเขตความสามารถ	65
9.3	เทคโนโลยีที่ใช้ในการพัฒนาโปรแกรม	66
9.3.1	ล็อกมอนิเตอร์ของไฟร์สกรีน	66
9.3.2	ล็อกมอนิเตอร์ของไฟร์อลาร์ม	67
9.3.3	ล็อกมอนิเตอร์ของไฟร์แทรป	68
9.3.4	ล็อกมอนิเตอร์ของไฟร์เบรก	69
9.4	การทำงานของโปรแกรม	69

สารบัญ (ต่อ)

บทที่ 10 การพัฒนาโปรแกรม Tartarus Management	
10.1 แนวคิด	71
10.2 ขอบเขตความสามารถ	71
10.3 การทำงานของโปรแกรม	71
บทที่ 11 การทดลองและผลการทดลอง	
11.1 โครงสร้างระบบ	78
11.2 ขั้นตอนการทดสอบชุดโปรแกรม	78
11.2.1 ทดสอบการทำงานของไฟร์สเตชัน	80
11.2.2 ทดสอบการทำงานของไฟร์สตาร์ม	82
11.2.3 ทดสอบการทำงานของไฟร์สกรีน	84
บทที่ 12 บทวิจารณ์และสรุป	
12.1 บทสรุป	91
12.2 วิจารณ์สิ่งที่ได้จากโครงงาน	91
12.3 ปัญหาอุปสรรคและแนวทางแก้ไข	92
12.4 แนวทางการพัฒนาต่อ	92
บรรณานุกรม	93

สารบัญตาราง

ตารางที่	หน้า
2.1 รูปแบบของแอคเซสรูลเบื้องต้น	5
2.2 ตัวอย่างของการตั้งค่าแอคเซสรูลของไฟร์วอลล์	5
4.1 รายละเอียดของแอตทริบิวต์ที่เพิ่มในฐานข้อมูลของแอ็คทีฟไดเรกทอรี	24
4.2 รายละเอียดคลาสที่เพิ่มในฐานข้อมูลของแอ็คทีฟไดเรกทอรี	24
4.3 รายละเอียดการทำงานของฟังก์ชันในคลาส ADConnect	26
5.1 แสดงความหมายของแต่ละค่า	36
9.1 แสดงโครงสร้างตารางที่ใช้ในการเก็บล็อกของเครื่องเกตเวย์	67
9.2 แสดงโครงสร้างตารางที่ใช้ในการเก็บล็อกของเครื่องลูกข่าย	68
11.1 ตารางกำหนดหมายเลขไอพีประจำเครื่องแต่ละเครื่อง	79

สารบัญรูป

รูปที่	หน้า
2.1 การทำงานของแอปพลิเคชันพรีอกรี	8
2.2 การทำงานของระบบตรวจจับผู้บุกรุกโดยวิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก	14
2.3 การทำงานของการตรวจจับผู้บุกรุกโดยวิธีตรวจสอบการใช้งานระบบที่ผิดปกติ	15
2.4 แสดงตำแหน่งของเว็บพรีอกรีในเครือข่าย	16
2.5 การทำงานของรีเวิร์สเว็บพรีอกรี	17
2.6 การทำงานของรีเวิร์สเว็บพรีอกรีแบบปลอดภัย	18
3.1 รูปภาพแสดงโครงสร้างของชุดโปรแกรมรักษาความปลอดภัยเครือข่าย	19
4.1 แสดงรูปแบบการเข้าถึง Active Directory Service	24
4.2 รายละเอียดของคลาส AD Connect	25
4.3 แสดงโครงสร้างการทำงานของไฟร์สเตชัน(FireStation)	26
5.1 แผนผังการทำงานของระบบไฟร์สกรีน	28
5.2 การรับกฎจากไฟร์สเตชัน	35
5.3 กฎในเซก LOG-CHAIN	36
5.4 แสดงการส่งล็อกของไฟร์สกรีน	37
6.1 รูปแสดงการทำงานแบบ Anonymous pipe	44
6.2 รูปแสดงการทำงานแบบ Named pipe	44
6.3 รูปแสดงการทำงานโปรแกรมไฟร์อลาร์ม	48
6.4 แสดงขั้นตอนการทำงานของไฟร์วอลล์	48
6.5 แสดงระดับชั้นการทำงานของ WinPCap	49
6.6 โครงสร้างของระบบตรวจจับผู้บุกรุกทำงานร่วมกับไฟร์วอลล์	50
6.7 แสดงโครงสร้างส่วนติดต่อกับเซิร์ฟเวอร์	50
6.8 รูปแสดงส่วนประกอบของ Service Control	51
6.9 รูปแสดงส่วนการรับและแสดงผลข้อมูลที่ได้จากไฟร์อลาร์มเซอร์วิส	52
7.1 แสดงการทำงานของ Sebek	54
7.2 รูปภาพแสดงการcaptureข้อมูลที่ทำภายใน kernel	54
7.3 รูปภาพแสดงการ by-pass ไม่ผ่าน TCP stack	55
7.4 รูปแสดงโปรโตคอลของเซเบค	56
7.5 รายงานการถูกสแกนพอร์ตโดย Syslogd	59

สารบัญรูป (ต่อ)

รูปที่		หน้า
7.6	Kernel Routing Table ภายหลังจากถูกเครื่อง 192.168.0.6 สแกนเข้ามา	59
7.7	ไฟล์ History ของ PortSentry	60
9.1	แสดงโครงสร้างการทำงานระหว่างล๊อคมอนิเตอร์กับแอ็คทีฟไคเร็คทอรี	69
10.1	แสดงหน้าจอล๊อคอินเข้าโปรแกรม	71
10.2	แสดงหน้า Status ของโปรแกรม Tartarus Management	72
10.3	แสดงรูปในส่วนที่ใช้ในการกำหนดกฎ ให้กับระบบตรวจจับผู้บุกรุก	73
10.4	แสดงรูปในส่วนที่ใช้ในการสร้างกฎ ให้กับระบบตรวจจับผู้บุกรุก	74
10.5	หน้าต่างส่วนจัดการเครื่องกับดัก	75
10.6	หน้าต่างของส่วนแสดงข้อมูลเครื่องกับดัก	76
10.7	หน้าต่างแสดงข้อมูลที่เก็บในเครื่องดาต้าเบสเซอร์ฟเวอร์ (LogServer)	77
10.8	หน้าต่างแสดงข้อมูลล๊อคไฟล์จากระบบไฟร์เบรก	77
11.1	แสดงโครงสร้างระบบที่ใช้ในการทดลอง	78
11.2	โปรแกรมไฟร์สเดชั่น	80
11.3	แสดงการกำหนดกฎตัวอย่าง	80
11.4	โปรแกรมไฟร์สเดชั่นส่วนของการกำหนดกฎให้กับไฟร์สกรีน	81
11.5	โปรแกรมไฟร์อลาร์ม	82
11.6	แสดงกฎการฟิเตอร์ที่รับมาจากเซิร์ฟเวอร์	82
11.7	แสดงสถานะของโปรเซสที่ใช้งานเครือข่าย	83
11.8	แสดงป๊อปอัพ (Popup) แสดงโปรเซสที่ใช้งานเครือข่าย	83
11.9	การแจ้งเตือนการบุกรุกหรือถูกโจมตี	84
11.10	แสดงกฎเริ่มต้นของไฟร์สกรีน	85
11.11	กฎจากไฟร์สเดชั่นที่เพิ่มเข้าไปในเซนฟอว์เวิร์ด	86
11.12	กฎจากไฟร์สเดชั่นที่เพิ่มเข้าไปในเซนอินพุท	86
11.13	ล๊อคที่แสดงขึ้นที่หน้าจอของไฟร์สกรีน	87
11.14	แสดงข้อมูลใน /var/log/firescreen.log	87
11.15	แสดงการสร้างเส้นทางให้ผู้บุกรุกเดินทางไปยังเครื่องกับดัก	88
11.16	แสดงเซอร์วิสที่โปรแกรม S2I ทำงานอยู่เพื่อตรวจสอบความอ่อนแอของเครื่องกับดัก	88
11.17	แสดงข้อมูลเกี่ยวกับการทำงานของเครื่องกับดัก	89
11.18	แสดงล๊อคไฟล์ที่บันทึกพฤติกรรมของผู้บุกรุกจากโปรแกรมเซเบค	90
11.19	แสดงขั้นตอนการทำงานเมื่อทำการอัปเดต Signature ของสนอร์ตอินไลน์	90